CYBERSECURITY DOMAINS AND SCOPES

A Research Report on Career Paths, Skills, and Certifications in Cybersecurity

---

Submitted in partial fulfilment of the Certified Ethical Hacker (CEH) Programme

NIAI | 2026

Report Date: 2nd March 2026

Introduction

Cybersecurity is not a single profession. It is a collection of specialised disciplines, each addressing a distinct set of threats, responsibilities, and organisational needs. This report is produced as part of the CEH programme and aims to present a clear, structured overview of the major cybersecurity career domains — what each entails, what skills it demands, what tools practitioners use, and what certifications are available to those pursuing each path.

The report examines ten domains that collectively cover the primary career paths available in cybersecurity as of 2026. These are: Penetration Testing, Security Operations Centre (SOC) Analysis, Digital Forensics, Incident Response, Malware Analysis, Cyber Threat Intelligence, Cloud Security, Application Security, Network Security, Governance, Risk & Compliance, and lastly Red Team / Blue Team Operations.

For each domain, the report provides a definition, a description of key responsibilities, the technical and soft skills required, the primary tools used and their purpose, the certifications most relevant to that domain (with guidance on when to pursue each), and a career progression outline with approximate salary ranges. Salary data is drawn from Glassdoor, Indeed, and Payscale (Q1 2026). Certification costs reflect official provider pricing as of March 2026.

A note on scope: this report is intended for an audience at the beginning of their cybersecurity journey.

Primary sources: ISC² Cybersecurity Workforce Study (September 2025); EC-Council CEH v13 Curriculum (2025); CompTIA State of Cybersecurity (Q4 2025); MarketsandMarkets domain market reports (2024–2025); Payscale, Indeed, and Glassdoor salary data (Q1 2026).

Domain 1: Penetration Testing

1.1 Definition and Overview

Penetration testing — commonly referred to as pentesting or ethical hacking — is the practice of intentionally attacking computer systems, networks, and applications with explicit written authorisation, with the objective of identifying security weaknesses before malicious actors can exploit them. The engagement is bound by a scope agreement, operates under a defined set of rules of engagement, and concludes with a formal report that communicates findings and remediation recommendations to the client.

Penetration testers simulate the techniques used by real adversaries. They conduct reconnaissance to gather information about the target, scan for vulnerabilities, attempt to exploit discovered weaknesses, and, where possible, move through the environment to demonstrate the full potential impact of a breach. The deliverable is not the breach itself but the detailed, actionable report that follows.

The penetration testing market was valued at USD 2.74 billion in 2024 and is projected to reach USD 5.03 billion by 2029 (MarketsandMarkets, Q4 2024). Demand for certified penetration testers grew 23% year-on-year through Q1 2026 (Indeed Hiring Lab, February 2026).

1.2 Key Responsibilities

A penetration tester is responsible for scoping engagements in collaboration with the client to define which systems, networks, and applications are in scope and what testing actions are permitted. From that point, the tester conducts reconnaissance to map the target's digital footprint, identifies and validates vulnerabilities, and exploits confirmed weaknesses to demonstrate impact. Where post-exploitation access is permitted, the tester will attempt lateral movement to show how far an attacker could progress. The engagement concludes with a detailed report that distinguishes confirmed vulnerabilities from theoretical risks, prioritises findings by severity, and provides specific, actionable remediation guidance. Retesting after remediation is typically included.

1.3 Required Technical Skills

Core technical competencies include a strong understanding of TCP/IP networking, operating system internals (particularly Linux and Windows), and web application architecture. Penetration testers must be proficient with scripting languages — primarily Python and Bash — for automating tasks and developing custom tools. Knowledge of the OWASP Top 10 web application vulnerabilities is essential for web-focused testing. Understanding of Active Directory architecture and its common attack patterns is increasingly required for enterprise engagements. Familiarity with exploit development concepts, password cracking techniques, and wireless security protocols rounds out the expected technical foundation.

1.4 Required Soft Skills

Penetration testers must communicate complex technical findings clearly and concisely to audiences that range from system administrators to C-suite executives. Report writing is a significant part of the role. Professional ethics and discretion are non-negotiable, as testers routinely encounter sensitive data and systems. Persistence and methodical thinking are practical necessities — most vulnerabilities are not

discovered on the first attempt. Client relationship management, including the ability to set and manage expectations, is increasingly expected even at mid-level positions.

1.5 Tools Used

Kali Linux	The standard operating system for penetration testing. A Debian-based Linux distribution pre-loaded with over 600 security tools. Used as the primary working environment for most pentest engagements.
Nmap	Network scanner. Identifies live hosts, open ports, running services, and OS details. Typically the first tool runs at the start of any network-facing engagement. Free and open-source.
Metasploit Framework	Exploitation framework containing hundreds of modules for known vulnerabilities across network services, applications, and operating systems. Used to validate and demonstrate exploitability of discovered weaknesses. Free (Community) and commercial (Pro).
Burp Suite	Web application testing platform. Intercepts and manipulates HTTP/HTTPS traffic between a browser and server. Used to test for injection flaws, authentication weaknesses, and access control issues. Community edition free; Professional: USD 449/year.
Wireshark	Network protocol analyser. Captures and inspects network packets in real time. Used to examine traffic for credentials, sensitive data, and evidence of malicious behaviour. Free and open-source.
BloodHound	Active Directory attack path mapper. Graphs relationships between users, groups, computers, and permissions to identify paths from a low-privilege account to domain administrator. Free and open-source.
Hashcat / John the Ripper	Password cracking tools. Hashcat uses GPU acceleration for high-speed hash cracking; John the Ripper is CPU-based. Both are used to verify whether captured password hashes can be reversed to plaintext.
Gobuster / ffuf	Directory and file brute-forcing tools. Used to discover hidden paths, files, and endpoints on web servers that are not publicly linked. Free and open-source.

1.6 Certifications

The table below outlines the most relevant certifications for penetration testers, ordered by the recommended stage of career at which they should be pursued.

CompTIA Security+ — CompTIA — USD 392	The recommended starting point for anyone entering cybersecurity, including penetration testing. Covers foundational security concepts. Highly recognised by employers and listed under the US DoD 8570.01-M framework. Pursue before or alongside CEH. URL: comptia.org/certifications/security
CEH v13 — EC-Council — USD 1,199 (exam)	The Certified Ethical Hacker credential. Covers all major phases of ethical hacking across 20 modules. DoD 8570 approved. Widely recognised by employers

	internationally. The core certification for this domain. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/
eJPT — eLearnSecurity — USD 200	Junior Penetration Tester. A practical, browser-based exam covering foundational network and web penetration testing. Recommended as the first hands-on practical certification, pursued 0–6 months after CEH. URL: elearnsecurity.com/certification/ejpt/
CompTIA PenTest+ — CompTIA — USD 392	Covers penetration testing planning, scoping, reporting, and legal considerations. DoD 8570.01-M listed. Valuable for roles in government and defence contracting. 0–6 months post-CEH. URL: comptia.org/certifications/pentest
OSCP — Offensive Security — USD 1,499	Offensive Security Certified Professional. A 24-hour practical exam requiring candidates to compromise multiple machines without multiple choice. The most respected practical penetration testing credential globally. Pursue 12–18 months after CEH, after dedicated preparation. URL: offsec.com/courses/pen-200/
GPEN — GIAC/SANS — ~USD 7,000 with training	GIAC Penetration Tester. Highly regarded in government and financial sectors. Open-book exam. Often employer-sponsored. Pursue 12–24 months post-CEH. URL: giac.org/certifications/penetration-tester-gpen/

1.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
Junior Penetration Tester	$65,000 – $90,000	Security+, CEH, eJPT	0–2 years
Penetration Tester	$90,000 – $130,000	CEH, OSCP	2–4 years
Senior Penetration Tester	$130,000 – $165,000	OSCP, GPEN	4–7 years
Penetration Testing Lead	$160,000 – $200,000	OSCP + specialisations	7–10 years
Security Consultant	$150,000 – $220,000+	Multiple + client portfolio	8+ years

Domain 2: Security Operations Centre (SOC) Analysis

2.1 Definition and Overview

A Security Operations Centre (SOC) is the function within an organisation responsible for continuously monitoring, detecting, investigating, and responding to cybersecurity threats. SOC analysts are the practitioners who operate this function. Their environment consists of security dashboards, alert queues, and data from SIEM (Security Information and Event Management) platforms that aggregate logs and events from across the organisation's entire IT infrastructure.

The SOC analyst's primary challenge is volume. A medium-to-large organisation generates millions of security events daily. The analyst must distinguish genuine threats — which are a small minority — from the background noise of normal, expected activity. This requires familiarity with normal behaviour patterns, knowledge of attacker techniques, and the discipline to investigate methodically under time pressure.

SOC analysis is consistently ranked among the most in-demand cybersecurity roles globally. The average SOC team faces a 40% staffing shortfall (ISACA State of Cybersecurity, Q3 2025), making this one of the most accessible entry points into cybersecurity for career changers.

2.2 Key Responsibilities

SOC analysts monitor security dashboards and alert queues continuously, typically in rotating shifts to maintain 24/7 coverage. When an alert is triggered, the analyst triages it — determining whether it represents a genuine threat or a false positive. Confirmed threats are escalated to a more detailed investigation, during which the analyst examines supporting log data, network traffic, and endpoint telemetry to establish the scope and nature of the incident. Where an active incident is confirmed, the analyst initiates the incident response process: containment, investigation, eradication, and recovery. Throughout, detailed records of all findings and actions are maintained. Senior SOC analysts additionally conduct threat hunting — proactively searching for attacker activity that automated tools have not detected.

2.3 Required Technical Skills

SOC analysts must be proficient with SIEM platforms — Splunk, Microsoft Sentinel, and IBM QRadar are the most common in enterprise environments. Log analysis is a core skill: reading and interpreting Windows Event Logs, Linux syslog, firewall logs, proxy logs, and application logs. Familiarity with endpoint detection and response (EDR) tools such as CrowdStrike Falcon and SentinelOne is increasingly expected even at junior levels. An understanding of network protocols and the ability to read packet captures in Wireshark rounds out the expected technical foundation. Scripting ability in Python or PowerShell is valuable for automating repetitive analysis tasks.

2.4 Required Soft Skills

The ability to remain methodical and calm under pressure is the defining soft skill for SOC work. Alert fatigue is a known occupational hazard, and analysts must maintain attention to detail across long shifts. Clear written communication is essential — incident reports and shift handover notes must be precise and unambiguous. Teamwork and reliable communication with colleagues across shifts is inherent to the function.

2.5 Tools Used

Splunk	The market-leading SIEM platform. Ingests log data from across the IT environment and provides a query language (SPL) for searching and analysing security events. The primary interface for most enterprise SOC analysts.
Microsoft Sentinel	Cloud-native SIEM and SOAR (Security Orchestration, Automation and Response) platform built on Microsoft Azure. Increasingly adopted in organisations with Microsoft-centric infrastructure. Includes AI-driven threat detection.
CrowdStrike Falcon	Leading EDR platform. Deploys a lightweight agent on endpoints and uses behavioural AI to detect malicious activity in real time. Among the most widely deployed enterprise endpoint security platforms as of 2025.
MITRE ATT&CK Framework	A publicly maintained knowledge base of adversary tactics and techniques based on real-world attack data. SOC analysts use it to map detected activities to known threat actor behaviours and identify coverage gaps. Free. URL: attack.mitre.org
TheHive / IRIS	Open-source incident response case management platforms. Allow SOC teams to track incidents, assign investigation tasks, and document findings and timelines throughout the response lifecycle.
VirusTotal / Hybrid Analysis	Threat intelligence and malware analysis platforms. Analysts submit suspicious files, URLs, or IP addresses to check against antivirus engines and automated behavioural sandboxes. VirusTotal: free tier and commercial.
Wireshark	Used in the SOC context for packet-level investigation when network-based threats need to be examined beyond what SIEM data provides.
Velociraptor	Endpoint forensics and live response tool. Allows SOC analysts to remotely collect forensic artefacts from endpoints at scale during active incident investigations. Free and open-source.

2.6 Certifications

CompTIA Security+ — USD 392	Foundation requirement for all SOC roles. Establishes baseline security concepts. Pursue before CEH. URL: comptia.org/certifications/security
CEH v13 — USD 1,199 (exam)	Understanding attacker methodologies makes SOC analysts significantly more effective at identifying and contextualising threats. CEH-certified SOC analysts identify threats more accurately due to their knowledge of how attacks are constructed. Core certification. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/
CompTIA CySA+ — USD 392	Cybersecurity Analyst certification. Bridges the gap between Security+ and senior SOC roles, covering threat intelligence, vulnerability management, and incident response. Pursue 0–6 months post-CEH. URL: comptia.org/certifications/cybersecurity-analyst
Microsoft SC-200 — USD 165	Microsoft Security Operations Analyst. Validates proficiency with Microsoft Sentinel, Defender XDR, and the Microsoft security stack. High practical value in

	organisations running Microsoft infrastructure. Pursue anytime post-CEH. URL: learn.microsoft.com/certifications/exams/sc-200
GCIA — GIAC/SANS — ~USD 7,000	GIAC Certified Intrusion Analyst. Deep coverage of network forensics and intrusion detection. Elite credential for network-focused SOC analysts. Often employer-sponsored. Pursue 6–18 months post-CEH. URL: giac.org/certifications/certified-intrusion-analyst-gcia/
GCIH — GIAC/SANS — ~USD 7,000	GIAC Certified Incident Handler. Focuses on the incident response process. Required or preferred for Tier 2 and Tier 3 SOC analysts. Pursue 6–18 months post-CEH. URL: giac.org/certifications/certified-incident-handler-gcih/

2.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
Tier 1 SOC Analyst	$50,000 – $75,000	Security+, CEH	0–2 years
Tier 2 SOC Analyst	$75,000 – $100,000	CySA+, SC-200	2–4 years
Tier 3 / Threat Hunter	$100,000 – $130,000	GCIA, GCIH	4–6 years
SOC Team Lead	$120,000 – $155,000	GCIH, CISSP	6–9 years
SOC Manager / Director	$150,000 – $195,000	CISSP, CISM	9–12 years

Domain 3: Digital Forensics and Incident Response (DFIR)

3.1 Definition and Overview

Digital Forensics and Incident Response — universally abbreviated as DFIR — is the discipline that addresses what happens after a security incident occurs. Digital forensics is the methodical collection, preservation, and analysis of digital evidence. Incident response is the operational process of containing an active threat, eradicating the attacker, restoring systems, and documenting the full scope of what happened. The two functions are typically combined into a single discipline because they depend on one another: effective incident response requires forensic evidence; forensic analysis is most valuable when it informs an active response.

DFIR professionals are called upon when an organisation suspects or has confirmed a breach. Their responsibilities include determining how the attacker gained entry, what systems and data were accessed or exfiltrated, what the attacker's tools and techniques were, and what must be done to fully remediate the environment. Their findings must be documented in a manner that withstands legal and regulatory scrutiny, as DFIR reports may be submitted to regulators, insurers, or courts.

The average cost of a data breach in 2025 was USD 4.88 million globally (IBM Cost of a Data Breach Report, July 2025). Organisations with dedicated DFIR capabilities reduced breach costs by an average of USD 1.49 million compared to those without.

3.2 Key Responsibilities

DFIR practitioners acquire forensic images of compromised systems — exact bit-for-bit copies of disk drives and memory — ensuring that original evidence is preserved and unmodified. They analyse these images for indicators of attacker activity: malware files, modified system artefacts, attacker tools and scripts, and evidence of data exfiltration. Memory forensics — analysing the contents of RAM — is an increasingly critical skill, as sophisticated attackers operate entirely in memory to avoid leaving disk artefacts. Network traffic forensics involves examining captured packets to identify C2 communications, lateral movement, and data transfers. Throughout the investigation, a chain of custody is maintained for all evidence. Final reports must detail the complete attack timeline, the attacker's methods, the full scope of impact, and remediation steps taken.

3.3 Required Technical Skills

Core technical skills include forensic disk analysis using tools such as Autopsy and Sleuth Kit, memory forensics using the Volatility framework, and network traffic analysis using Wireshark and Zeek. Malware analysis at a triage level — determining what a suspicious file does without full reverse engineering — is expected. Deep knowledge of Windows internals (Registry, Event Logs, Prefetch files, Amcache, ShimCache) and Linux audit trail artefacts is essential. YARA rule writing for malware detection is a valuable specialist skill. Cloud forensics — collecting and interpreting evidence from AWS CloudTrail, Azure Monitor, and GCP Logging — is an emerging requirement as cloud adoption continues.

3.4 Required Soft Skills

Composure under pressure is the paramount soft skill for DFIR work. Active incidents are chaotic, timelines are compressed, and decisions made in the first hours can have significant consequences. Objective, evidence-driven reporting is essential — DFIR professionals must report what the evidence

shows, not what the organisation hopes it shows. Clear written communication across technical and non-technical audiences is required daily. Discretion is critical, as DFIR practitioners encounter highly sensitive personal and business data routinely.

3.5 Tools Used

Autopsy / Sleuth Kit	Open-source digital forensics platform. Examines forensic disk images, recovers deleted files, analyses browser history, email artefacts, and file system metadata. The primary free forensics workbench used by law enforcement and corporate investigators worldwide.
Volatility 3	The standard memory forensics framework. Analyses RAM dumps from Windows, Linux, and macOS to extract running processes, network connections, loaded drivers, and injected malicious code. Free and open-source.
Velociraptor	Endpoint forensics and live response tool. Deploys agents across enterprise environments and allows remote collection of forensic artefacts at scale. Particularly valuable during large-scale incident response. Free and open-source.
Magnet AXIOM / AXIOM Cyber	Commercial forensics platform widely used in law enforcement and corporate investigations. Provides automated evidence processing, timeline analysis, and case management. ~USD 6,000/year. Accepted in legal proceedings.
YARA	Pattern matching tool for identifying malware based on file content characteristics. DFIR analysts write YARA rules to scan environments for malware variants following an investigation. Free and open-source.
Cuckoo Sandbox / ANY.RUN	Malware sandboxes. Execute suspicious files in isolated environments and log all resulting behaviour — files created, network connections, registry modifications. ANY.RUN is cloud-based and interactive. Free tiers available.
Plaso / log2timeline	Digital forensic timeline creation tool. Aggregates timestamps from dozens of artefact types into a unified chronological timeline for investigation. Essential for establishing the complete sequence of attacker activity. Free.
NetworkMiner / Zeek	Network forensics tools. NetworkMiner reconstructs files and credentials from packet captures; Zeek produces structured network logs at scale from captured traffic. Both free and open-source.

3.6 Certifications

CompTIA Security+ — USD 392	Essential foundation. Pursue before CEH.
CEH v13 — USD 1,199 (exam)	Understanding attack techniques is prerequisite knowledge for reconstructing them during forensic analysis. Core certification for this domain. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/

GCFE — GIAC/SANS — ~USD 7,000	GIAC Certified Forensic Examiner. Windows-focused forensic analysis. Highly regarded in both corporate and law enforcement contexts. Pursue 6–12 months post-CEH. URL: giac.org/certifications/certified-forensic-examiner-gcfe/
GCFA — GIAC/SANS — ~USD 7,000	GIAC Certified Forensic Analyst. Advanced memory forensics, malware analysis, and incident response. The top-tier DFIR credential. Pursue 12–24 months post-CEH. URL: giac.org/certifications/certified-forensic-analyst-gcfa/
CISA — ISACA — USD 575 (member)	Certified Information Systems Auditor. Adds compliance and audit capability to DFIR expertise. Valued in regulated industries. Requires 3–5 years experience. URL: isaca.org/credentialing/cisa
EnCE — OpenText	EnCase Certified Examiner. Validates expertise in the EnCase forensics platform, widely used in law enforcement and government. Required for many government DFIR positions. URL: opentext.com/products/encase-forensic

3.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
Junior DFIR Analyst	$60,000 – $85,000	Security+, CEH	0–2 years
DFIR Analyst	$85,000 – $115,000	GCFE, GCFA	2–4 years
Senior DFIR / IR Lead	$115,000 – $155,000	GCFA + specialisations	4–7 years
DFIR Consultant	$140,000 – $200,000	GCFA, CISA	5–10 years
Director of DFIR / IR	$175,000 – $250,000+	GCFA, CISSP	10+ years

Domain 4: Malware Analysis

4.1 Definition and Overview

Malware analysis is the process of examining malicious software to determine its purpose, functionality, behaviour, and origin. A malware analyst receives a suspicious file — a ransomware binary, a banking trojan, a rootkit — and systematically dissects it to answer specific questions: what does it do, how does it communicate, what data does it target, and what characteristics can be used to detect it across other systems. The outputs of malware analysis feed into the SOC (as detection signatures), DFIR (as investigation context), and threat intelligence (as attribution evidence).

The field is divided into static analysis — examining the file's code and structure without executing it — and dynamic analysis — running the malware in a controlled environment and observing what it does. Advanced analysts combine both approaches and apply reverse engineering techniques to fully understand obfuscated or packed samples.

AI-generated and polymorphic malware has become a significant challenge as of 2025. Threat actors are using large language models to generate code variants that evade signature-based detection, placing greater emphasis on behaviour-based analysis skills.

4.2 Key Responsibilities

Malware analysts receive samples from threat intelligence feeds, incident response investigations, or detection alerts. Initial triage involves a rapid assessment of the file type, embedded strings, imported functions, and network indicators using basic static analysis. Deeper investigation involves disassembling or decompiling the sample to understand its logic, and running it in a sandbox to observe its behaviour. Analysts document their findings in technical analysis reports, write YARA rules and other detection signatures based on their findings, and may contribute attribution assessments by comparing code characteristics against known malware families. In larger organisations, analysts also manage the malware sample repository and sandbox infrastructure.

4.3 Required Technical Skills

Assembly language reading ability is a prerequisite for serious malware analysis work — compiled malware executes at the instruction level, and disassemblers present it in assembly form. Proficiency with disassembly and decompilation tools, particularly Ghidra and IDA Pro, is expected. Thorough knowledge of the Windows PE (Portable Executable) file format, Windows API functions, and how malware abuses them is foundational. Sandbox analysis using Cuckoo, ANY.RUN, or similar platforms is a daily task. Scripting in Python is used for automation, custom analysis tooling, and YARA rule development. Network protocol knowledge is required to analyse malware C2 communications.

4.4 Required Soft Skills

Malware analysis demands sustained patience and methodical discipline. A single obfuscated sample may require days of focused investigation. The ability to document findings precisely and reproducibly is essential — other analysts must be able to follow the same steps and arrive at the same conclusions. Clear technical writing is required for analysis reports. Continued learning is non-negotiable in a field where the threat landscape changes daily.

4.5 Tools Used

Ghidra (NSA/Open-Source)	Free reverse engineering framework developed and released by the National Security Agency in 2019. Disassembles and decompiles malware across multiple processor architectures. Has substantially lowered the barrier to entry for malware reverse engineering. Free and open-source.
IDA Pro / IDA Free	The industry-standard disassembler. IDA Pro (commercial, ~USD 1,800+) remains the most powerful and widely used tool in professional malware analysis environments. IDA Free provides a limited subset of functionality. Free and commercial versions.
x64dbg	Open-source debugger for Windows 32-bit and 64-bit executables. Allows analysts to step through malware execution instruction by instruction, inspecting memory and registers at each point. Used to defeat anti-analysis techniques. Free.
ANY.RUN	Interactive cloud-based malware sandbox. Analysts submit suspicious files and observe execution in real time through a browser interface. File system changes, network connections, and process activity are logged automatically. Free tier and commercial plans.
Cuckoo Sandbox	Open-source automated malware analysis system. Executes samples in isolated virtual machines and generates comprehensive behavioural reports. The foundation of many enterprise and research malware analysis labs. Free.
YARA	Pattern matching language for identifying malware based on file characteristics. Used across the industry to write detection rules that identify malware families and variants across large file sets. Free and open-source.
Fakenet-NG	Network simulation tool. Intercepts malware network communications and responds with simulated services, allowing analysts to capture and study C2 traffic without connecting to live malicious infrastructure. Free and open-source.
PE Studio / CFF Explorer	Static analysis tools for examining the structure of Windows PE files. Used for initial triage — extracting imported functions, embedded strings, section characteristics, and other metadata before any dynamic analysis is performed. Free.

4.6 Certifications

CompTIA Security+ — USD 392	Foundation. Pursue before CEH.
CEH v13 — USD 1,199 (exam)	Module 7 covers malware threats, types, and attacker deployment techniques. Understanding how malware is used offensively is prerequisite context for analysing it defensively. Core certification. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/

eCMAP — eLearnSecurity — ~USD 400	Certified Malware Analysis Professional. Practical malware analysis certification at a more accessible price point than GIAC credentials. A useful mid-stage credential before committing to GREM. Pursue 6–18 months post-CEH.
GREM — GIAC/SANS — ~USD 7,000	GIAC Reverse Engineering Malware. The elite credential in malware analysis. Based on the SANS FOR610 course. Covers static and dynamic analysis, obfuscation, packing, rootkits, and network traffic analysis. Pursued by government intelligence analysts and senior researchers. Pursue 12–24 months post-CEH. URL: giac.org/certifications/reverse-engineering-malware-grem/

4.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
Junior Malware Analyst	$70,000 – $95,000	Security+, CEH	0–2 years
Malware Analyst	$95,000 – $130,000	eCMAP, GREM	2–5 years
Senior Malware Researcher	$130,000 – $170,000	GREM + publications	5–8 years
Threat Intelligence Engineer	$140,000 – $185,000	GREM + CTI credentials	5–10 years
Principal Researcher	$170,000 – $230,000+	Advanced RE portfolio	10+ years

Domain 5: Cyber Threat Intelligence (CTI)

5.1 Definition and Overview

Cyber Threat Intelligence is the discipline of systematically collecting, processing, and analysing information about threats — their sources, techniques, targets, and indicators — to produce actionable knowledge that informs security decisions. CTI professionals do not operate defensive tools directly. Their value lies in the intelligence they produce for those who do.

CTI operates at three levels. Strategic intelligence provides senior leadership with high-level context: which threat actors are targeting the organisation's industry, what geopolitical factors are relevant, and what the risk landscape looks like over the coming months. Operational intelligence informs security managers about specific threat campaigns, including which actor groups are active, what infrastructure they are using, and who their current targets are. Tactical intelligence delivers technical indicators — malicious IP addresses, domain names, file hashes — that can be directly ingested by automated security tools such as firewalls and SIEM platforms.

The MITRE ATT&CK framework (current version 16.1, Q4 2025) has become the universal taxonomy for describing adversary behaviours. Fluency with ATT&CK is a baseline requirement for every CTI professional.

5.2 Key Responsibilities

CTI analysts collect intelligence from a range of sources: open-source news and research, commercial threat feeds, government and law enforcement feeds, dark web forums, and internal data from the organisation's own security tools. They process this raw information to extract relevant indicators and context, then analyse it to produce finished intelligence products — reports, briefings, and IOC feeds — appropriate to each audience. A significant part of the role involves tracking specific threat actor groups over time, maintaining profiles of their motivations, targets, tools, and techniques. Dark web monitoring for mentions of the organisation, stolen credentials, or planned attacks is an increasingly standard responsibility. CTI analysts also participate in industry information sharing groups (ISACs — Information Sharing and Analysis Centres) to exchange intelligence with peer organisations.

5.3 Required Technical Skills

Advanced OSINT (open-source intelligence) methodology is the foundation of CTI technical skills — including the use of advanced search operators, domain and IP pivoting, document metadata extraction, and social media intelligence. Expert knowledge of the MITRE ATT&CK framework and ability to map adversary behaviours to specific techniques is expected. Scripting in Python is used extensively for automating intelligence collection and processing pipelines. Familiarity with threat intelligence platforms such as MISP, Anomali ThreatStream, and Recorded Future is required for structured intelligence management. A working knowledge of malware analysis is needed to interpret technical reports from analysts and extract relevant indicators.

5.4 Required Soft Skills

Critical and analytical thinking is the most important soft skill in CTI. Analysts must assess the credibility of sources, identify potential disinformation or seeding, and distinguish reliable intelligence from noise. Precise written communication is central to the role — finished intelligence reports must convey

complex findings clearly and with appropriate confidence levels. Knowledge of geopolitics and adversary culture (including, where possible, foreign language reading ability) is a meaningful differentiator in senior roles.

5.5 Tools Used

MISP	Malware Information Sharing Platform. Open-source threat intelligence platform for storing, sharing, and correlating indicator data. Used by government agencies, CERTs, and enterprises worldwide. Free and community-supported.
Recorded Future	Commercial threat intelligence platform. Uses AI to collect and analyse data from millions of open, dark web, and technical sources. Provides finished intelligence and raw indicator feeds. Enterprise contract pricing (~USD 100,000+/year).
Maltego	OSINT and relationship-mapping tool. Visualises connections between entities — IP addresses, domains, email addresses, individuals — to map attacker infrastructure and relationships. Community edition free; commercial from USD 999/year.
Shodan	Search engine for internet-connected devices. Used to discover attacker infrastructure — C2 servers, malicious hosting — by searching for specific technical fingerprints. Essential for infrastructure attribution. Free tier and commercial plans.
OpenCTI	Open-source CTI platform developed by the French cybersecurity agency ANSSI. Provides a structured environment for managing and sharing intelligence using the STIX standard. A capable, free alternative to commercial platforms.
MITRE ATT&CK Navigator	Free browser-based tool for visualising adversary technique coverage against the ATT&CK matrix. Used for threat actor profiling, detection gap analysis, and communicating intelligence findings. URL: mitre-attack.github.io/attack-navigator/
SpiderFoot / Recon-ng	Automated OSINT frameworks. SpiderFoot aggregates intelligence from hundreds of sources automatically; Recon-ng provides a modular, targeted reconnaissance framework. Both free and open-source.
VirusTotal Intelligence	Advanced threat intelligence layer. Allows searching across 70+ antivirus engines and millions of samples by file characteristics, network patterns, and behaviour. Commercial: ~USD 10,000+/year.

5.6 Certifications

CompTIA Security+ — USD 392	Foundation. Pursue before CEH.
CEH v13 — USD 1,199 (exam)	OSINT and reconnaissance methodology covered in CEH Modules 2 and 3 map directly to CTI collection tradecraft. Core certification. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/

CTIA — EC-Council — USD 499	Certified Threat Intelligence Analyst. EC-Council's dedicated CTI credential. Covers the full intelligence lifecycle from planning through dissemination. A natural companion to CEH. Pursue alongside or immediately post-CEH. URL: eccouncil.org/train-certify/certified-threat-intelligence-analyst-ctia/
GCTI — GIAC/SANS — ~USD 7,000	GIAC Cyber Threat Intelligence. Covers intelligence theory, adversary analysis, and technical CTI methodology. Elite credential in government and enterprise sectors. Pursue 12–18 months post-CEH. URL: giac.org/certifications/cyber-threat-intelligence-gcti/
CISA — ISACA — USD 575 (member)	Adds compliance and audit dimension valuable in regulated industries where CTI feeds governance functions. Requires 3–5 years experience. URL: isaca.org/credentialing/cisa

5.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
CTI Analyst (Junior)	$65,000 – $90,000	Security+, CEH, CTIA	0–2 years
CTI Analyst	$90,000 – $125,000	CTIA, GCTI	2–4 years
Senior CTI Analyst	$120,000 – $160,000	GCTI + specialisation	4–7 years
CTI Manager / Lead	$150,000 – $195,000	GCTI, CISSP	7–10 years
Head of Threat Intelligence	$175,000 – $260,000	GCTI, CISM, CISSP	10+ years

Domain 6: Cloud Security

6.1 Definition and Overview

Cloud security is the practice of protecting data, applications, and infrastructure that operate in cloud computing environments. As of 2025, the majority of enterprise workloads run on one or more public cloud platforms — primarily Amazon Web Services (AWS), Microsoft Azure, and Google Cloud Platform (GCP). This shift has fundamentally changed the security landscape: there is no longer a physical network perimeter to defend, configurations can change in seconds through API calls, and the shared responsibility model means organisations remain accountable for security even though they do not own the underlying infrastructure.

Cloud misconfigurations are the dominant cause of cloud-related breaches. An incorrectly configured storage bucket, an overly permissive IAM (Identity and Access Management) policy, or an exposed API endpoint can expose sensitive data to the entire internet. Cloud security professionals specialise in identifying, preventing, and remediating these conditions. The cloud security workforce gap is the most acute of any cybersecurity domain as of Q1 2026 (CyberSeek/NICE, February 2026).

The global cloud security market was valued at USD 40.8 billion in 2024 and is projected to grow to USD 116.5 billion by 2029 at a compound annual growth rate of 23.2% (MarketsandMarkets, Q1 2025).

6.2 Key Responsibilities

Cloud security professionals are responsible for reviewing the security architecture of cloud deployments — assessing VPC configurations, IAM policies, network security group rules, encryption settings, and logging configurations. IAM management and governance is the most critical daily function: ensuring that every user, application, and service has precisely the access required and no more. Cloud Security Posture Management (CSPM) tools are used to continuously scan cloud environments for misconfigurations and compliance violations. Container and Kubernetes security is an increasing responsibility as containerised workloads become the standard deployment model. DevSecOps integration — embedding security controls into CI/CD pipelines and reviewing infrastructure-as-code templates before deployment — is a growing focus across the field.

6.3 Required Technical Skills

Practical proficiency with the security services of at least one major cloud provider — and familiarity with the others — is the core technical requirement. Deep understanding of IAM across AWS, Azure, and GCP is the single most valued cloud security skill. Scripting in Python, Bash, and infrastructure-as-code tools (Terraform, Pulumi) is required for implementing and automating security controls at scale. Container security — Docker security configuration, Kubernetes RBAC, pod security policies — is increasingly required. Understanding cloud networking concepts (VPCs, subnets, security groups, private endpoints) is distinct from traditional networking and must be learned specifically.

6.4 Required Soft Skills

Cloud security professionals must work in close collaboration with development and DevOps teams. Security requirements must be communicated as enabling rather than obstructive, and controls must be designed to integrate into development workflows rather than impede them. The ability to translate technical risk findings into business impact language is required for executive reporting. Adaptability is

intrinsic to the role — cloud platforms release hundreds of new features annually, and the security implications of each must be assessed.

6.5 Tools Used

AWS Security Hub / GuardDuty	Native AWS security services. GuardDuty performs intelligent threat detection across AWS accounts using machine learning and threat intelligence. Security Hub aggregates findings from GuardDuty, Inspector, and other services into a unified view. Included in AWS Free Tier with usage-based pricing.
Microsoft Defender for Cloud	CSPM and workload protection platform for Azure, AWS, and GCP. Provides security score, compliance assessment against regulatory frameworks, and workload threat detection. Integrated with Microsoft Sentinel.
Wiz	Agentless cloud security platform. Scans entire cloud environments without deploying agents and provides a risk graph showing relationships between resources, misconfigurations, and vulnerabilities. Among the fastest-growing cloud security platforms of 2024–2025. Enterprise pricing.
Prisma Cloud (Palo Alto Networks)	Leading commercial CNAPP (Cloud-Native Application Protection Platform). Covers code, infrastructure, and runtime security across multi-cloud environments. Enterprise market leader. Enterprise pricing.
Prowler	Open-source cloud security assessment tool for AWS, Azure, and GCP. Runs hundreds of security checks based on CIS benchmarks and regulatory frameworks. The standard free cloud security assessment tool. Free and open-source.
Trivy / Grype	Container and IaC vulnerability scanners. Trivy scans Docker images, file systems, and Terraform/CloudFormation templates for known vulnerabilities and misconfigurations before deployment. Free and open-source.
Checkov	Static analysis tool for infrastructure-as-code. Scans Terraform, CloudFormation, Kubernetes manifests, and other IaC formats for security misconfigurations before deployment. Integrates into CI/CD pipelines. Free and open-source.
ScoutSuite	Open-source multi-cloud security auditing tool. Produces a detailed HTML report of security configuration issues across AWS, Azure, and GCP. Widely used for initial cloud security assessments and audits. Free and open-source.

6.6 Certifications

CompTIA Security+ — USD 392	Foundation. Pursue before CEH.
CEH v13 — USD 1,199 (exam)	Module 19 (Cloud Computing Hacking) covers cloud-specific attack techniques and security architecture. The attacker perspective on cloud environments is prerequisite for effective cloud defence. Core certification. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/

AWS Certified Security – Specialty — USD 300	The most sought-after cloud security credential for AWS environments. Validates deep knowledge of AWS security services and architecture. High employer recognition in AWS-deployed organisations. Pursue 6–12 months post-CEH. URL: aws.amazon.com/certification/certified-security-specialty/
AZ-500: Microsoft Azure Security — USD 165	Microsoft's cloud security specialist credential. Covers identity management, platform protection, and data security in Azure. Very high value in Microsoft-centric organisations. Pursue 6–12 months post-CEH. URL: learn.microsoft.com/certifications/exams/az-500
CCSP — ISC2 — USD 599 (exam)	Certified Cloud Security Professional. Vendor-neutral, architecture-level cloud security certification. Requires 5 years experience (or CISSP as substitute). The senior-level cloud security credential. Pursue at 2–3 years experience. URL: isc2.org/certifications/ccsp
Google Professional Cloud Security Engineer — USD 200	Validates expertise in Google Cloud security architecture and services. High value in GCP-focused organisations. URL: cloud.google.com/certification/cloud-security-engineer

6.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
Cloud Security Analyst	$75,000 – $105,000	Security+, AWS Security	0–2 years
Cloud Security Engineer	$105,000 – $145,000	AWS/AZ-500, CCSP	2–4 years
Senior Cloud Security Eng.	$145,000 – $190,000	CCSP, multi-cloud certs	4–7 years
Cloud Security Architect	$175,000 – $235,000	CCSP, CISSP	7–10 years
Head of Cloud Security	$200,000 – $290,000	CCSP, CISSP, CISM	10+ years

Domain 7: Application Security (AppSec)

7.1 Definition and Overview

Application security, commonly abbreviated as AppSec, is the discipline of identifying, preventing, and remediating security vulnerabilities within software applications. As organisations have moved their services and operations online, web and mobile applications have become the primary interface between organisations and their customers, partners, and employees. This makes them a primary target for attackers.

Traditional security approaches — a penetration test conducted once per year — cannot match the pace of modern software development, where code is released continuously across dozens of applications. AppSec professionals therefore work to integrate security throughout the software development lifecycle (SDLC), from threat modelling at the design phase, through automated security scanning in CI/CD pipelines, to manual penetration testing before major releases.

The OWASP (Open Web Application Security Project) Foundation is the authoritative source for application security standards. The OWASP Top 10 — a ranked list of the most critical web application vulnerability categories, most recently published in 2021 — is the foundational reference document for the field. URL: owasp.org/Top10. Bug bounty programmes paid USD 292 million in rewards in 2024 (HackerOne Hacker-Powered Security Report, April 2025), demonstrating the scale of the independent security researcher ecosystem that supplements internal AppSec functions.

7.2 Key Responsibilities

AppSec professionals conduct threat modelling sessions with development teams at the design phase of new features and applications, identifying potential attack vectors before any code is written. They perform static application security testing (SAST) by analysing source code for vulnerability patterns using automated tools and manual code review. Dynamic application security testing (DAST) involves testing running applications by simulating attacker behaviour. Software Composition Analysis (SCA) is used to identify vulnerable open-source libraries and frameworks in an application's dependency tree. API security testing has grown significantly in scope as APIs have become the dominant application architecture. AppSec professionals also deliver security training to developers, design and manage bug bounty programmes, and track discovered vulnerabilities through to confirmed remediation.

7.3 Required Technical Skills

A thorough, exploitable-depth understanding of the OWASP Top 10 vulnerabilities is the core technical requirement for AppSec work. Burp Suite Pro is the essential web application testing tool, and proficiency with it is expected at all levels. Familiarity with at least one programming language — ideally one used in the development environments the analyst will be reviewing — is necessary for effective code review and meaningful communication with developers. Knowledge of SAST tools (Semgrep, SonarQube, Checkmarx) and SCA tools (Snyk, Dependabot) is required for integration into development pipelines. API security testing skills, including familiarity with REST and GraphQL security considerations and tools such as Postman, are increasingly critical.

7.4 Required Soft Skills

Empathy with developers is the most consistently cited differentiator between effective and ineffective AppSec professionals. Security findings must be communicated as practical, addressable problems rather than criticism. Teaching ability is a significant component of the role at every level — security improvements scale through developer education more than through individual testing. The ability to prioritise pragmatically, accepting that not every vulnerability can be addressed immediately and focusing effort on the highest-impact risks, distinguishes effective practitioners from perfectionist ones.

7.5 Tools Used

Burp Suite Pro — PortSwigger	The essential web application security testing platform. Provides a intercepting proxy, scanner, intruder (automated input fuzzing), repeater (manual request manipulation), and additional tools for web application analysis. Community edition free; Professional: USD 449/year.
OWASP ZAP	Open-source web application scanner maintained by OWASP. Provides automated scanning and a proxy for manual testing. Widely integrated into CI/CD pipelines for automated security testing. Free.
Semgrep	Open-source static analysis tool. Uses YAML-based rules to identify security vulnerabilities in source code. Integrates directly into developer IDEs and CI/CD pipelines. Large community rule library available. Free open-source; commercial Pro tier available.
SonarQube	Code quality and security platform. Scans code for bugs, security vulnerabilities, and maintainability issues. Widely adopted in enterprise development environments. Community edition free; Enterprise: from USD 15,000/year.
Snyk / Dependabot	Software Composition Analysis tools. Automatically identify vulnerable open-source dependencies and surface remediation options. Snyk provides the most comprehensive SCA coverage commercially (~USD 98+/month). Dependabot is free via GitHub.
Postman / Insomnia	API development and testing tools. Used by AppSec professionals to construct and send arbitrary API requests, test authentication and authorisation logic, and systematically explore API endpoints for security vulnerabilities. Postman free tier available.
OWASP Threat Dragon	Threat modelling tool. Allows development and security teams to create data-flow diagrams and identify potential threats at the application design phase. Free and open-source. URL: owasp.org/www-project-threat-dragon/
ffuf / gobuster	Web fuzzing tools. Used to discover hidden directories, files, parameters, and endpoints by systematically testing a large number of possible values. Free and open-source.

7.6 Certifications

CompTIA Security+ — USD 392	Foundation. Pursue before CEH.

CEH v13 — USD 1,199 (exam)	Modules 13 (Web Server Hacking) and 14 (Web Application Hacking) cover the attacker methodology for web-facing systems. The attacker perspective is prerequisite context for AppSec work. Core certification. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/
eWPT — eLearnSecurity — ~USD 200	Web Application Penetration Tester. Practical web application testing certification. A well-structured and affordable first hands-on AppSec credential. Pursue 0–6 months post-CEH. URL: elearnsecurity.com/certification/ewpt/
BSCP — PortSwigger — USD 99/attempt	Burp Suite Certified Practitioner. PortSwigger's practical certification based on the Web Security Academy lab platform. Growing recognition as a practical skills validation, particularly in the independent security researcher community. Pursue 6–18 months post-CEH. URL: portswigger.net/web-security/certification
OSWE — Offensive Security — USD 1,499	Advanced Web Attacks and Exploitation. White-box source code review and exploitation. The elite practical credential for AppSec specialists. Pursue 18–36 months post-CEH. URL: offsec.com/courses/web-300/
GWEB — GIAC/SANS — ~USD 7,000	GIAC Web Application Defender. Defensive application security credential. Covers secure development practices and application protection techniques. Pursue 12–24 months post-CEH. URL: giac.org/certifications/web-application-defender-gweb/

7.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
AppSec Analyst (Junior)	$70,000 – $95,000	Security+, CEH, eWPT	0–2 years
Application Security Engineer	$95,000 – $140,000	BSCP, OSWE	2–5 years
Senior AppSec Engineer	$135,000 – $175,000	OSWE, GWEB	5–8 years
AppSec Architect	$165,000 – $225,000	OSWE + cloud certs	8–12 years
Head of Product Security	$195,000 – $275,000	CISSP + portfolio	10+ years

Domain 8: Network Security

8.1 Definition and Overview

Network security encompasses the policies, procedures, and technologies used to control, monitor, and protect the network infrastructure of an organisation. It is the longest-established of all cybersecurity domains, predating the internet's public availability, and remains foundational. Regardless of how significantly other aspects of the technology landscape have evolved, data must traverse networks, and networks must be protected.

The scope of network security has expanded considerably from its origins in firewall management and perimeter defence. Modern network security encompasses next-generation firewall administration, intrusion detection and prevention, network access control, zero-trust network architecture, network detection and response (NDR), secure access service edge (SASE), and wireless security. The traditional perimeter-based model — in which internal network traffic was implicitly trusted — has been replaced by zero-trust architecture, which operates on the principle that no user or device is trusted by default regardless of network location.

68% of organisations reported network-based attacks as one of the top three threat vectors in Q3 2025 (Ponemon Institute, September 2025). Network security remains a mandatory function in every organisation globally.

8.2 Key Responsibilities

Network security professionals design and maintain firewall rule sets, ensuring that only authorised traffic is permitted and that all policies are documented and periodically reviewed. IDS/IPS (Intrusion Detection and Prevention Systems) must be configured and continuously tuned to detect genuine threats while minimising false positives. Network Access Control systems enforce policies that prevent non-compliant or unauthorised devices from joining the network. VPN infrastructure for remote access must be designed securely and maintained with current software and configuration standards. Continuous monitoring of network traffic for anomalies and indicators of compromise is a core ongoing responsibility. Network security professionals also conduct or support penetration testing of network infrastructure and translate findings into remediation actions.

8.3 Required Technical Skills

Expert-level TCP/IP networking knowledge is the bedrock of network security. This includes subnetting, routing protocols (BGP, OSPF), switching concepts (VLANs, spanning tree), and a thorough understanding of how each protocol functions and how it can be abused. Proficiency with at least one enterprise firewall platform — Palo Alto Networks, Cisco ASA/Firepower, Fortinet FortiGate, or Check Point — is expected in most roles. Packet analysis with Wireshark at an expert level is a baseline requirement. Scripting and automation — Python, Bash, Ansible — are increasingly required as network environments scale beyond manual management.

8.4 Required Soft Skills

Systems thinking is essential. Networks are complex, interdependent systems, and changes to one component can have unintended consequences elsewhere. Thorough change documentation and disciplined change management processes are therefore not optional hygiene, but professional

necessities. Cross-team collaboration — with operations, application development, and compliance functions — is constant. Every firewall policy decision involves a tradeoff between security and business functionality, requiring an understanding of business context that goes beyond pure technical knowledge.

8.5 Tools Used

Wireshark	Network protocol analyser. Captures and inspects network packets at the most granular level available. Used for fault diagnosis, incident investigation, and security analysis. Required knowledge for every network security professional. Free and open-source.
Nmap	Network discovery and security auditing tool. Maps live hosts, open ports, running services, and OS fingerprints across a network. The standard tool for network inventory and security assessment. Free and open-source.
Suricata / Snort	Open-source intrusion detection and prevention systems. Suricata is the current preferred option due to its multi-threaded architecture and high throughput performance. Compatible with the Emerging Threats ruleset for threat detection. Free.
Palo Alto Networks Panorama	Centralised management platform for Palo Alto next-generation firewalls. Provides unified policy management, logging, and reporting across distributed firewall deployments. The most advanced enterprise firewall management ecosystem as of 2025.
Zeek (formerly Bro)	Network analysis framework. Generates high-level, structured log data — connection summaries, DNS queries, HTTP sessions, SSL certificates — from network traffic at scale. Feeds directly into SIEM platforms. Free and open-source.
Cisco Identity Services Engine (ISE)	The leading enterprise Network Access Control solution. Enforces policy-based device access, performs device profiling and posture assessment, and integrates with active directory for user-based access control.
Nessus Professional — Tenable	Vulnerability scanner. Identifies known vulnerabilities, misconfigurations, and compliance violations across network devices, servers, and endpoints. USD 3,990/year. The market-standard vulnerability assessment tool.
WireGuard / OpenVPN	VPN protocols and implementations. WireGuard has become the modern standard for high-performance, cryptographically robust VPN tunnels, with broad adoption in enterprise environments since its Linux kernel integration in 2020. Free and open-source.

8.6 Certifications

CompTIA Network+ — USD 338	Recommended if networking fundamentals are not already established. Validates the foundational networking knowledge that all network security work depends on. Pursue before Security+ if needed. URL: comptia.org/certifications/network

CompTIA Security+ — USD 392	Foundation. Pursue before CEH.
CEH v13 — USD 1,199 (exam)	Provides the attacker perspective on network vulnerabilities, which is the essential context for designing effective network defences. Core certification. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/
Cisco CCNA — USD 330	Cisco Certified Network Associate. Validates foundational Cisco networking knowledge. Given Cisco's dominant position in enterprise networking infrastructure, CCNA is highly regarded by employers. Pursue alongside or before CEH in a networking career path. URL: cisco.com/c/en/us/training-events/training-certifications/certifications/associate/ccna.html
CompTIA CySA+ — USD 392	Strong defensive security credential with significant network security coverage. Pursue 0–6 months post-CEH.
PCNSE — Palo Alto Networks	Palo Alto Networks Certified Network Security Engineer. Validates expert-level knowledge of Palo Alto firewall configuration, management, and troubleshooting. High market value in organisations running Palo Alto infrastructure. Pursue 12–24 months post-CEH. URL: paloaltonetworks.com/services/education/certification
GAWN — GIAC/SANS — ~USD 7,000	GIAC Assessing and Auditing Wireless Networks. Specialist wireless security certification. Valuable for organisations with complex or high-risk wireless environments. Pursue 12–18 months post-CEH. URL: giac.org/certifications/assessing-auditing-wireless-networks-gawn/

8.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
Network Security Analyst	$65,000 – $95,000	Security+, CEH, CCNA	0–2 years
Network Security Engineer	$90,000 – $130,000	CySA+, PCNSE	2–5 years
Senior Network Security Eng.	$125,000 – $165,000	PCNSE, GAWN	5–8 years
Network Security Architect	$160,000 – $215,000	CISSP + vendor certs	8–12 years
Director, Network Security	$185,000 – $255,000+	CISSP, CISM	12+ years

Domain 9: Governance, Risk and Compliance (GRC)

9.1 Definition and Overview

Governance, Risk and Compliance — universally known as GRC — is the organisational and management layer of cybersecurity. Where other domains focus primarily on technical controls and operational security functions, GRC addresses the frameworks, policies, and accountability structures that ensure an organisation's cybersecurity programme is structured, documented, measurable, and aligned with legal and regulatory obligations.

Governance refers to the structures and processes that define how security decisions are made: who is responsible, how policy is established and maintained, how performance is measured, and how the security function is accountable to executive leadership and the board. Risk management is the formal process of identifying, assessing, and deciding how to treat cybersecurity risks — accepting, mitigating, transferring through insurance, or avoiding them — in a manner that is documented and defensible. Compliance is the process of demonstrating to regulators, auditors, and business partners that the organisation meets required standards: PCI-DSS for payment card data, HIPAA for healthcare information, GDPR for the personal data of European citizens, SOC 2 for cloud service providers.

GRC professionals are among the most senior and highest-compensated practitioners in cybersecurity. The skill of translating technical security realities into organisational accountability and legal compliance language is genuinely rare and commands corresponding compensation. The GRC market is projected to grow from USD 52.5 billion in 2025 to USD 76.3 billion by 2029 (MarketsandMarkets, Q4 2024).

9.2 Key Responsibilities

GRC professionals develop, maintain, and enforce security policies that govern organisational security behaviour. They conduct formal risk assessments using established frameworks — NIST RMF, ISO 27005, FAIR — to identify, prioritise, and document cybersecurity risks in terms that the business can act upon. Regulatory compliance management involves mapping the organisation's controls against applicable standards, identifying and remediating gaps, and maintaining the evidence required for audit. Third-party and vendor risk management — assessing the security posture of suppliers and partners who have access to the organisation's data or systems — is an increasingly substantial responsibility. Executive and board reporting translates technical security posture into risk language appropriate for governance-level decision-making. GRC professionals also oversee security awareness training programmes and ensure incident response processes meet legal breach notification requirements.

9.3 Required Technical Skills

GRC professionals require fluency with the major regulatory frameworks and standards: NIST Cybersecurity Framework 2.0 (released February 2024), ISO 27001:2022, NIST SP 800-53, CIS Controls v8, PCI-DSS v4.0, and GDPR. Proficiency with GRC platform software — ServiceNow GRC, RSA Archer, OneTrust, Vanta, or Drata — is expected in most enterprise roles. Risk quantification methodology, particularly the FAIR (Factor Analysis of Information Risk) framework for expressing cybersecurity risk in financial terms, is a highly valued technical skill. IT audit methodology — the process of assessing controls, collecting evidence, and documenting findings in a defensible manner — is foundational for roles with a compliance focus.

9.4 Required Soft Skills

Executive communication is the defining soft skill for GRC work. GRC professionals present regularly to boards and regulators, and must communicate complex technical risk in concise, accurate terms appropriate for senior non-technical audiences. Influence without authority is a practical necessity: most security improvements require the cooperation of teams and individuals who do not report to the security function. Legal and regulatory literacy — the ability to read and accurately interpret legislation, standards, and contractual requirements — is a genuine differentiator. Business acumen, including an understanding of how security investment decisions compete with other organisational priorities, is essential at every level above entry.

9.5 Tools Used

ServiceNow GRC	The market-leading enterprise GRC platform. Manages risk registers, control libraries, audit workflows, and compliance evidence collection at scale. Widely deployed in large enterprises and financial institutions. Enterprise licensing.
OneTrust	Privacy and compliance management platform. Particularly strong for GDPR, CCPA, and privacy compliance management. Increasingly adopted as the standard for privacy GRC programmes. Enterprise licensing.
RSA Archer	Established enterprise GRC platform with strong penetration in financial services and government. Provides risk management, compliance management, and incident management capabilities. Enterprise licensing.
Vanta / Drata	Modern automated compliance platforms. Connect directly to cloud infrastructure (AWS, Azure, GCP, GitHub, Okta) and automatically collect evidence for SOC 2, ISO 27001, HIPAA, and other frameworks. Significantly reduce the manual burden of compliance programmes. Approximately USD 20,000–150,000/year.
NIST Cybersecurity Framework 2.0	Not a software platform, but the foundational framework against which most GRC programmes are structured. Free public resource from the US National Institute of Standards and Technology. URL: nist.gov/cyberframework
UpGuard / SecurityScorecard	Vendor risk management platforms. Continuously assess the external security posture of third-party vendors and generate risk scores. Critical for organisations with significant supply chain risk exposure. Enterprise pricing.
Qualys / Tenable.io (Compliance Modules)	Vulnerability and compliance scanning platforms with automated checks against CIS benchmarks, PCI-DSS, and other regulatory standards. Provide automated technical evidence collection for compliance programmes.
Archer / LogicGate Risk Cloud	Modern cloud-native GRC platforms that automate risk workflow, evidence collection, and reporting. Growing adoption as more agile alternatives to legacy installed platforms.

9.6 Certifications

CompTIA Security+ — USD 392	Foundation. Establishes technical baseline that gives GRC professionals credibility when assessing security controls. Pursue before CEH.

CEH v13 — USD 1,199 (exam)	Provides technical depth that significantly improves the quality of risk assessment and control evaluation work. A GRC professional who understands attack techniques assesses controls far more accurately. Complementary to GRC specialisation. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/
CISA — ISACA — USD 575 (member)	Certified Information Systems Auditor. The premier credential for audit and compliance-focused GRC practitioners. Particularly valued in financial services, healthcare, and government. Requires 5 years experience (waivable to 3 in some circumstances). Pursue at 3–5 years experience. URL: isaca.org/credentialing/cisa
CRISC — ISACA — USD 575 (member)	Certified in Risk and Information Systems Control. The top risk management credential globally. Covers IT risk identification, assessment, response, and monitoring. Requires 3 years experience in relevant roles. Pursue at 3–5 years experience. URL: isaca.org/credentialing/crisc
CISM — ISACA — USD 575 (member)	Certified Information Security Manager. The premier management-focused security credential and the primary qualification for CISO and senior GRC leadership roles. Requires 5 years experience in security management. Pursue at 5+ years experience. URL: isaca.org/credentialing/cism
CISSP — ISC2 — USD 749	Certified Information Systems Security Professional. The most widely recognised senior security credential globally. Eight domains covering the full breadth of security governance, risk, and management. Required for most Director and CISO-level positions. Requires 5 years experience. URL: isc2.org/certifications/cissp
ISO 27001 Lead Auditor	Validates expertise in auditing against the ISO 27001 information security management standard. Required for GRC professionals supporting or leading ISO 27001 certification programmes. Multiple accredited training providers, approximately USD 2,000–5,000.

9.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
GRC Analyst	$65,000 – $95,000	Security+, CEH	0–2 years
Senior GRC Analyst	$90,000 – $120,000	CISA, CRISC	2–5 years
GRC Manager	$115,000 – $160,000	CISM, CRISC	5–8 years
Director of GRC / Risk	$155,000 – $210,000	CISM, CISSP	8–12 years
CISO	$220,000 – $400,000+	CISSP, CISM, executive exp.	15+ years

Domain 10: Red Team / Blue Team Operations

10.1 Definition and Overview

Red Team and Blue Team operations represent the most advanced and operationally realistic form of security testing and defence available. The terms are borrowed from military training exercises, where an opposing force (red) attacks and a defending force (blue) responds. In cybersecurity, the Red Team simulates real-world advanced adversaries — using genuine attack techniques, genuine tools, and patient, stealthy tactics — against an organisation's live systems and people. The Blue Team operates the defensive security function — SOC, incident response, threat hunting — attempting to detect and eject the red team in real time. Neither team knows exactly what the other will do.

Red Team engagements differ from penetration tests in scope, duration, and objective. A penetration test identifies vulnerabilities across a defined scope over a short timeframe and reports them. A red team engagement simulates a sustained adversary campaign — potentially lasting weeks or months — against the organisation's full attack surface, including people and physical security, with the objective of determining whether the blue team would detect and respond to a real attack. The deliverable is not a vulnerability list but a realistic assessment of the organisation's detection and response capability.

The Purple Team concept — in which red and blue teams collaborate and share findings in real time during exercises — has grown significantly in adoption between 2023 and 2025 as organisations recognise that the greatest security improvement comes from combining red team offensive knowledge with blue team defensive infrastructure.

10.2 Key Responsibilities

Red Team responsibilities include adversary simulation: replicating the specific tactics, techniques, and procedures (TTPs) of threat actor groups most relevant to the client's industry and threat profile. Engagements begin with initial access operations — phishing, physical social engineering, external infrastructure exploitation — before moving into persistence establishment, lateral movement through the environment, and ultimately reaching high-value targets such as domain controllers and financial systems. Throughout, red team operators specifically attempt to evade the blue team's detection capabilities. Red team engagements conclude with detailed reports that map all activity to MITRE ATT&CK and provide specific, actionable recommendations for improving detection coverage.

Blue Team responsibilities within this context include operating detection tooling, conducting proactive threat hunting, responding to any red team activity that triggers alerts, and performing post-exercise analysis to understand what was detected, what was missed, and why. Detection engineers on the blue team write and refine SIEM rules and EDR signatures based on red team findings to close detection gaps.

10.3 Required Technical Skills — Red Team

Advanced Active Directory attack techniques — Kerberoasting, AS-REP Roasting, Pass-the-Hash, DCSync — are foundational red team skills. Expert-level knowledge of C2 (command-and-control) frameworks such as Cobalt Strike, Havoc, and Sliver is required for enterprise red team operations. Malware development — writing custom implants in C, C++, or Go that evade modern EDR platforms — is a specialist skill that distinguishes senior red team operators. Operational security (OPSEC) — minimising forensic evidence of red team activity to maintain the realism of the simulation — is a professional discipline in its own right. A thorough understanding of network protocols, authentication mechanisms, and Windows internals underpins all of the above.

10.4 Required Technical Skills — Blue Team

Detection engineering — the ability to write SIEM detection rules in Splunk SPL, Microsoft KQL, or Elastic EQL — is the core technical skill for blue team specialists. Expert-level proficiency with at least one SIEM platform and one EDR platform is required. Incident response and digital forensics skills are needed to investigate and validate red team activity when it is detected. Network traffic analysis, threat hunting methodology, and familiarity with the MITRE ATT&CK framework are foundational.

10.5 Required Soft Skills

For red team operators, creativity — the ability to find unexpected attack paths that standard tools and methodologies do not surface — and patience — the willingness to operate slowly and methodically over extended timeframes without triggering detection — are the defining characteristics of exceptional practitioners. For blue team professionals, collaborative discipline and precise communication across team members and shifts are essential. Both functions require exceptional professional ethics: the access and knowledge involved in both roles demands a standard of integrity that cannot be compromised.

10.6 Tools Used

Cobalt Strike (Red)	The most widely used commercial adversary simulation platform. Provides flexible C2, payload staging, and comprehensive post-exploitation capabilities. Licensed exclusively for legitimate security testing use. USD 6,000+/year. The de facto standard for enterprise red team C2 operations.
Havoc / Sliver (Red)	Open-source C2 frameworks. Sliver in particular has seen rapid adoption (2022–2025) as a capable alternative to Cobalt Strike, with the advantage that its signatures are less established in blue team detection tooling. Free and open-source.
BloodHound / SharpHound (Red)	Active Directory attack path analysis. BloodHound visualises privilege escalation paths between users, groups, computers, and domain objects. SharpHound collects the underlying AD data. Fundamental to every enterprise red team engagement. Free and open-source.
Impacket (Red)	Python library providing implementations of network protocols for use in attack tooling. Used for Pass-the-Hash attacks, credential extraction (secretsdump), and Kerberos abuse. The essential Active Directory attack toolkit. Free and open-source.
Splunk / Microsoft Sentinel (Blue)	The primary SIEM platforms for blue team detection work. Detection engineers write rules in SPL (Splunk) and KQL (Sentinel) to identify attacker activity from log data. Both support correlation across thousands of data sources.
Sigma (Blue)	Open-source, vendor-neutral detection rule format. Write one Sigma rule and convert it to Splunk SPL, Microsoft KQL, Elastic EQL, or any other major SIEM query language. The emerging detection engineering standard. Free and open-source. URL: github.com/SigmaHQ/sigma

MITRE ATT&CK / ATT&CK Navigator (Both)	Red teams map all activity to ATT&CK techniques during engagements. Blue teams map their detection coverage against the same framework to identify gaps. Purple team exercises are structured entirely around ATT&CK. Free. URL: attack.mitre.org
Atomic Red Team (Blue/Purple)	Library of small, controlled tests mapped to ATT&CK techniques. Allows blue teams to verify that their detection rules actually fire against specific adversary behaviours before encountering them in a real incident. Free and open-source. URL: github.com/redcanaryco/atomic-red-team

10.7 Certifications

CompTIA Security+ — USD 392	Foundation. Pursue before CEH.
CEH v13 — USD 1,199 (exam)	The CEH curriculum covers the full attack methodology — reconnaissance through post-exploitation — that forms the foundation of red team operations. It is the required entry certification for this career path. URL: eccouncil.org/train-certify/certified-ethical-hacker-ceh/
OSCP — Offensive Security — USD 1,499 (Red)	The industry-standard practical penetration testing credential. Every red team operator is expected to hold OSCP or an equivalent practical certification. The 24-hour practical exam structure validates genuine skill. Pursue 12–18 months post-CEH. URL: offsec.com/courses/pen-200/
CRTO — Zero-Point Security — USD 500 (Red)	Certified Red Team Operator. Covers Cobalt Strike, Active Directory attacks, detection evasion, and C2 infrastructure. Practitioner-built and practitioner-respected. Exceptional value relative to cost. Pursue 12–18 months post-CEH. URL: training.zeropointsecurity.co.uk
OSEP — Offensive Security — USD 1,499 (Red)	Experienced Penetration Tester. Advanced evasion, Active Directory attack chains, and C2 infrastructure. Post-OSCP credential for serious red team practitioners. Pursue 24–48 months post-CEH. URL: offsec.com/courses/pen-300/
GCIH — GIAC/SANS — ~USD 7,000 (Blue)	GIAC Certified Incident Handler. Core credential for blue team incident responders. Pursue 6–18 months post-CEH. URL: giac.org/certifications/certified-incident-handler-gcih/
GCFA — GIAC/SANS — ~USD 7,000 (Blue)	GIAC Certified Forensic Analyst. Advanced forensic analysis and malware-focused incident response. Elite credential for senior blue team practitioners. Pursue 12–24 months post-CEH. URL: giac.org/certifications/certified-forensic-analyst-gcfa/
GXPN — GIAC/SANS — ~USD 7,000 (Red)	GIAC Exploit Researcher and Advanced Penetration Tester. Elite offensive credential. Government and financial sector benchmark for senior red team practitioners. Pursue 24–36 months post-CEH. URL: giac.org/certifications/exploit-researcher-advanced-penetration-tester-gxpn/

10.7 Career Path and Growth Opportunities

Role	Salary Range (USD)	Certifications Required	Typical Timeline
Red Team Operator (Junior)	$80,000 – $110,000	CEH, OSCP	0–2 years
Red Team Operator	$110,000 – $150,000	OSCP, CRTO	2–5 years
Senior Red Team Operator	$145,000 – $200,000	CRTO, OSEP	5–8 years
Red Team Lead	$175,000 – $235,000	OSEP, GXPN	8–12 years
Blue Team Engineer	$80,000 – $120,000	CEH, GCIH	0–4 years
Purple Team Lead	$150,000 – $205,000	Combined skillset	7–12 years

Certification Reference Summary

The following table consolidates all certifications referenced in this report into a single reference, ordered from foundational to advanced. Cost figures reflect official provider pricing as of March 2026. Domain applicability indicates the primary domains for which each certification is relevant, though most credentials carry value across multiple areas.

Certification	Provider	Cost (USD)	Primary Domain(s)	Recommended Stage
CompTIA Network+	CompTIA	$338	Network Security	Pre-Security+ if needed
CompTIA Security+	CompTIA	$392	All Domains (Foundation)	Before CEH — required
CEH v13	EC-Council	$1,199 (exam)	All Domains (Core)	Core — pursue as primary
CTIA	EC-Council	$499	Threat Intelligence	Alongside/post CEH
eJPT	eLearnSecurity	$200	Penetration Testing	0–6 months post-CEH
eWPT	eLearnSecurity	~$200	Application Security	0–6 months post-CEH
eCMAP	eLearnSecurity	~$400	Malware Analysis	6–18 months post-CEH
CompTIA CySA+	CompTIA	$392	SOC, Network Security	0–6 months post-CEH
CompTIA PenTest+	CompTIA	$392	Penetration Testing	0–6 months post-CEH
Microsoft SC-200	Microsoft	$165	SOC Analysis	Anytime post-CEH
AZ-500	Microsoft	$165	Cloud Security (Azure)	6–12 months post-CEH
AWS Security Specialty	Amazon	$300	Cloud Security (AWS)	6–12 months post-CEH
Google Cloud Security	Google	$200	Cloud Security (GCP)	6–12 months post-CEH
Cisco CCNA	Cisco	$330	Network Security	Alongside CEH (net. path)
BSCP	PortSwigger	$99/attempt	Application Security	6–18 months post-CEH
OSCP	Offensive Security	$1,499	Pentesting, Red Team	12–18 months post-CEH
CRTO	Zero-Point Security	$500	Red Team Operations	12–18 months post-CEH
OSWE	Offensive Security	$1,499	Application Security	18–36 months post-CEH
OSEP	Offensive Security	$1,499	Red Team (Advanced)	24–48 months post-CEH
PCNSE	Palo Alto Networks	Varies	Network Security	12–24 months post-CEH
GCIA	GIAC / SANS	~$7,000	SOC, Network Security	6–18 months post-CEH
GCIH	GIAC / SANS	~$7,000	SOC, Blue Team, DFIR	6–18 months post-CEH
GCFE	GIAC / SANS	~$7,000	Digital Forensics	6–12 months post-CEH
GCFA	GIAC / SANS	~$7,000	DFIR (Advanced)	12–24 months post-CEH
GREM	GIAC / SANS	~$7,000	Malware Analysis	12–24 months post-CEH

GCTI	GIAC / SANS	~$7,000	Threat Intelligence	12–18 months post-CEH
GAWN	GIAC / SANS	~$7,000	Network / Wireless	12–18 months post-CEH
GWEB	GIAC / SANS	~$7,000	Application Security	12–24 months post-CEH
GPEN	GIAC / SANS	~$7,000	Penetration Testing	12–24 months post-CEH
GXPN	GIAC / SANS	~$7,000	Red Team (Elite)	24–36 months post-CEH
CCSP	ISC2	$599 (exam)	Cloud Security	2–3 years experience
CISA	ISACA	$575 (member)	GRC, DFIR (Audit)	3–5 years experience
CRISC	ISACA	$575 (member)	GRC, Risk Management	3–5 years experience
CISM	ISACA	$575 (member)	GRC, Management	5+ years experience
CISSP	ISC2	$749	All Domains (Senior)	5 years experience

References

Certification Provider URLs

The following URLs represent the official pages for each certification provider referenced in this report, verified as of March 2026.

- EC-Council (CEH v13, CTIA): eccouncil.org/train-certify/certified-ethical-hacker-ceh/
- CompTIA (Security+, Network+, CySA+, PenTest+): comptia.org/certifications
- Offensive Security (OSCP, OSWE, OSEP): offsec.com
- GIAC / SANS Institute (GPEN, GCIA, GCIH, GCFE, GCFA, GREM, GCTI, GAWN, GWEB, GXPN): giac.org/certifications
- ISC2 (CISSP, CCSP): isc2.org/certifications
- ISACA (CISM, CISA, CRISC): isaca.org/credentialing
- eLearnSecurity (eJPT, eWPT, eCMAP): elearnsecurity.com/certification
- PortSwigger (BSCP, Web Security Academy): portswigger.net/web-security/certification
- Zero-Point Security (CRTO, CRTL): training.zeropointsecurity.co.uk
- Amazon Web Services (AWS Security Specialty): aws.amazon.com/certification/certified-security-specialty/
- Microsoft (AZ-500, SC-200): learn.microsoft.com/certifications
- Cisco (CCNA): cisco.com/c/en/us/training-events/training-certifications/certifications/associate/ccna.html
- Palo Alto Networks (PCNSE): paloaltonetworks.com/services/education/certification
- Google Cloud (Professional Cloud Security Engineer): cloud.google.com/certification/cloud-security-engineer

Market Research and Industry Data

- ISC2 Cybersecurity Workforce Study 2025. isc2.org/research/workforce-study. Published September 2025.
- IBM Cost of a Data Breach Report 2025. ibm.com/security/data-breach. Published July 2025.
- ISACA State of Cybersecurity 2025. isaca.org. Published Q3 2025.
- EC-Council CEH 2025 Salary Report. eccouncil.org. Published Q3 2025.
- MarketsandMarkets: Penetration Testing Market Report. Q4 2024.
- MarketsandMarkets: Cloud Security Market Report. Q1 2025.
- MarketsandMarkets: Cyber Threat Intelligence Market Report. Q3 2024.
- MarketsandMarkets: GRC Market Report. Q4 2024.
- Veracode State of Software Security 2025. veracode.com. Published 2025.
- HackerOne 2025 Hacker-Powered Security Report. hackerone.com. Published April 2025.
- Chainalysis Crypto Crime Report 2024. chainalysis.com. Published February 2024.
- Ponemon Institute: Network Security Survey Q3 2025. ponemon.org. Published September 2025.
- Indeed Hiring Lab: Cybersecurity Demand Report. February 2026.

- CyberSeek / NICE: Cybersecurity Supply/Demand Heat Map. cyberseek.org. February 2026.
- LinkedIn Workforce Insights: Cybersecurity Job Posting Analysis. December 2025.
- Glassdoor, Indeed, Payscale: Salary data. Q4 2025 – Q1 2026.

Frameworks and Standards

- MITRE ATT&CK Framework v16.1. attack.mitre.org. Updated Q4 2025.
- NIST Cybersecurity Framework 2.0. nist.gov/cyberframework. Published February 2024.
- OWASP Top 10. owasp.org/Top10. Published 2021.
- CIS Controls v8. cisecurity.org/controls. Published May 2021.
- ISO/IEC 27001:2022. iso.org/standard/27001. Published October 2022.
- NIST SP 800-53 Rev. 5. csrc.nist.gov. Published September 2020, updated through 2024.
- FAIR Risk Quantification Framework. fairinstitute.org.
- Sigma Detection Rules. github.com/SigmaHQ/sigma.
- Atomic Red Team. github.com/redcanaryco/atomic-red-team. Red Canary, 2017–present.